

Securing FPGA based Systems

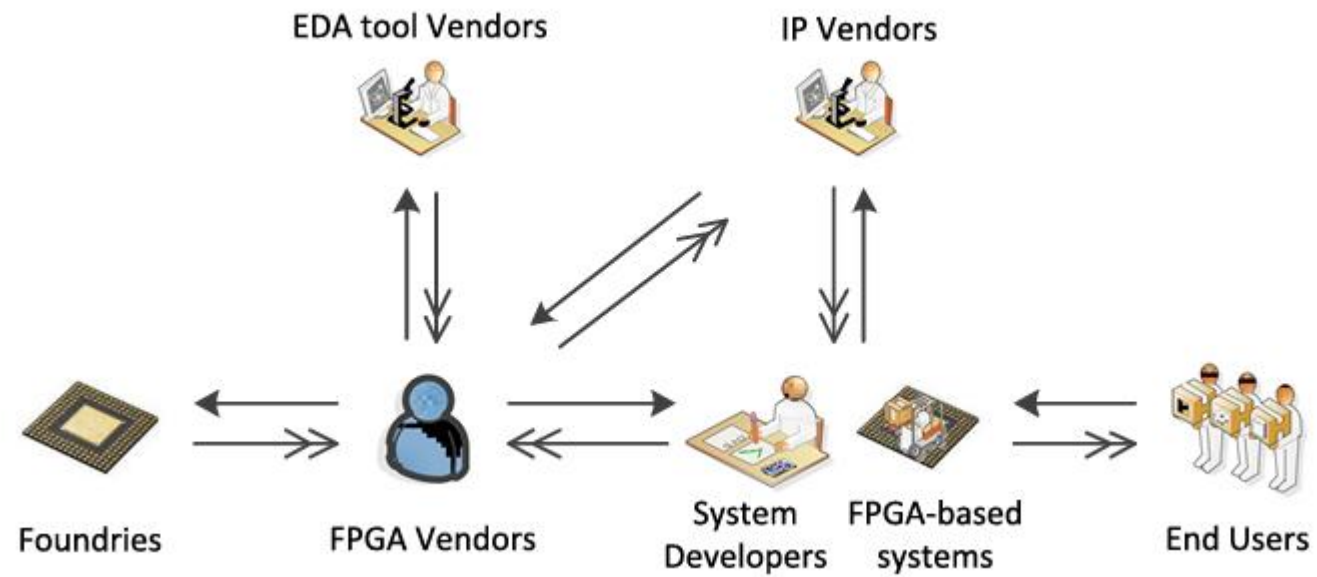


Fig. 1. The supply-and-demand flows in the FPGA-based system market.

"→": service requesting; "→→": service providing.

Cloning

- An attacker obtains FPGA bitstream and programs one or more unauthorized FPGAs with an identical configuration.
- Volatile FPGAs (like Xilinx, Intel/Altera) require:
 - the **bitstream** (configuration file) to be loaded from external flash every time the FPGA powers up
 - The bitstream travels through lines like SPI / QSPI/JTAG
- Attacker can -Program the same design onto another FPGA

Identification Friend or Foe.

- The “friend” is an authorized FPGA running the original design.
The “foe” is a cloned FPGA containing an unauthorized bitstream.

Identification Friend or Foe.

Each FPGA is paired with an external “safety device.”

This external device contains:

- A **secret key** stored in **secure EEPROM**
- A **hash function**

FPGA stores the same secret key inside its bitstream.

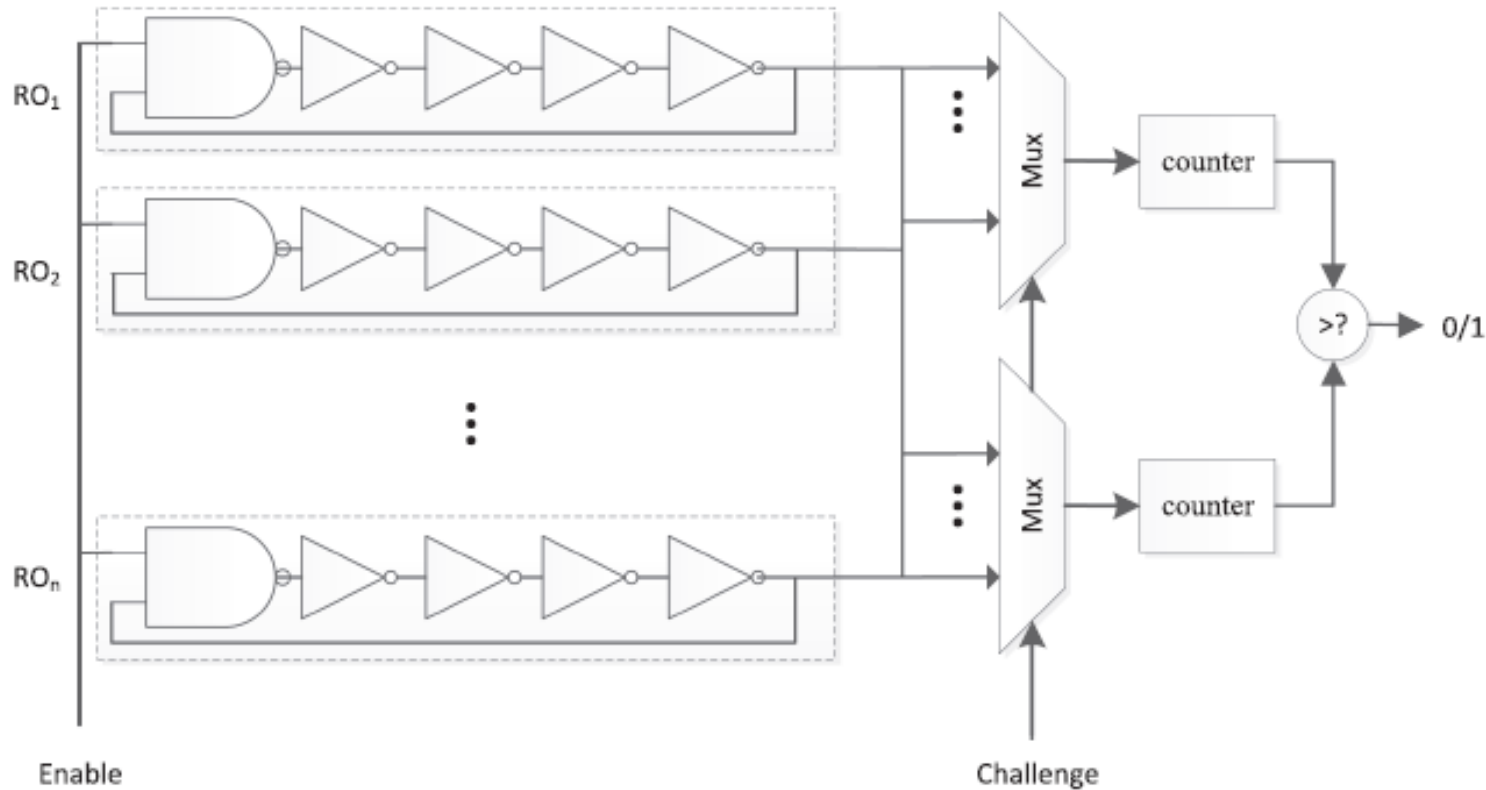
- When the FPGA boots, it extracts this key from the bitstream.

- During authentication:
 - FPGA sends a random challenge C to EEPROM.
- EEPROM computes:
 - $\text{Response_EEPROM} = \text{Hash}(\text{Key_EEPROM}, C)$
- FPGA computes:
 - $\text{Expected_Response} = \text{Hash}(\text{Key_FPGA}, C)$
- If both match → Friend
- If not → Foe (cloned FPGA)

PUF (Physically Unclonable Function)

- A **PUF** is a hardware circuit that produces a **unique, unpredictable, device-specific response**, derived from microscopic manufacturing variations.
- Even if two chips are manufactured identically, tiny physical differences make their responses different.
- These differences **cannot be cloned, predicted, or copied**, even by the manufacturer.

PUF (Physically Unclonable Function)



A ring oscillator is a loop of an odd number of inverters

When enabled, the signal propagates around the ring and oscillates continuously

Frequency = $1 / (\text{total delay of inverters})$

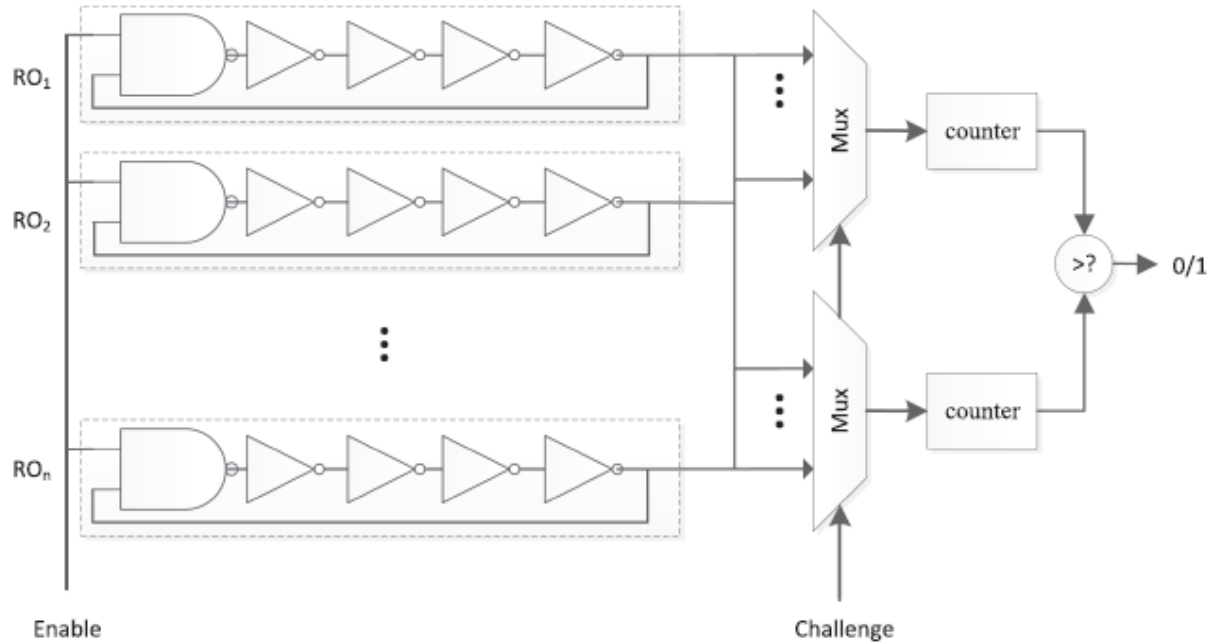
Transistor threshold voltage variations

Wire delay variations

Mismatch in transistor sizing

Random dopant fluctuations

PUF (Physically Unclonable Function)



Multiple Ring Oscillators (RO₁, RO₂, ..., RO_n)

Two multiplexers (MUXes)

Two counters

A comparator that outputs 0 or 1

A challenge that selects which oscillators to compare

- An enable signal that activates the oscillators

If RO_i is faster, Counter1 > Counter2 → output 1

If RO_j is faster, Counter2 > Counter1 → output 0

By applying many (i, j) pairs, the system generates a **response vector** → a unique device fingerprint.

Hardware Trojan

- Any intentional, malicious modification of an integrated circuit (IC) that alters its functionality, leaks information, degrades performance, or causes the system to fail under certain conditions.
- Can be inserted at *any stage of the design or manufacturing process*.
- Its purpose is to **change the behavior** of the hardware in a harmful way **only under specific conditions**, so it remains hidden during normal testing
- *Virus inside a chip!!!!* But inserted at the **hardware** level.

Major Parts of a Hardware Trojan

- **Trigger**

- Conditions under which the Trojan becomes active
 - Usually rare events so it stays hiddenExamples:
 - Rare input pattern
 - Specific sequence of operations
 - External signal (RF, temperature, voltage)

- **Payload**

- What the Trojan does once triggered.
Examples:
 - Leak secret keys
 - Disable the chip
 - Change computations
 - Reduce performance
 - Modify security checks
 - Open backdoor communication

Backdoor Communication

- **Backdoor communication** refers to any **unauthorized or hidden communication channel** built inside an FPGA design that:
 - bypasses normal interfaces (AXI, GPIO, PCIe, etc.)
 - leaks sensitive data, cryptographic keys
 - allows hidden control of FPGA logic
 - is not visible to the legitimate designer or the user
- It is a **secret communication path** implanted during:
 - RTL design
 - IP integration
 - Bitstream generation
 - Fabrication (foundry-level Trojan)

Why is it called a “Backdoor”?

- Because it behaves like a **secret door** into the FPGA:
 - Invisible to normal design tools
 - Undocumented
 - Often triggered only under specific rare conditions
 - Provides the attacker remote access or control

Examples

- **Covert Channels (hidden data path)**

- A small piece of logic passes sensitive information to attacker-controlled pins or modules.

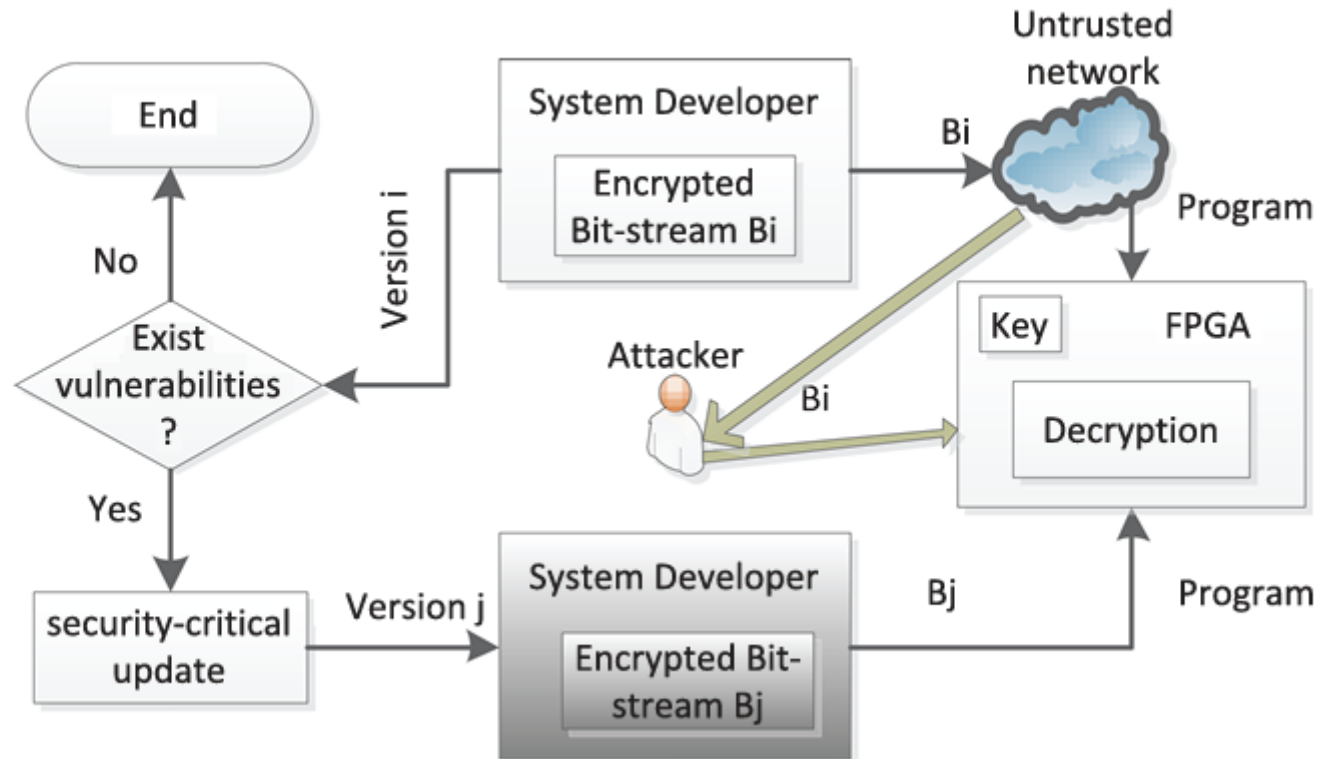
- **Malicious IP cores**

A vendor IP may include:

- Hidden UART communication
- Extra AXI master interface
- Undocumented control registers

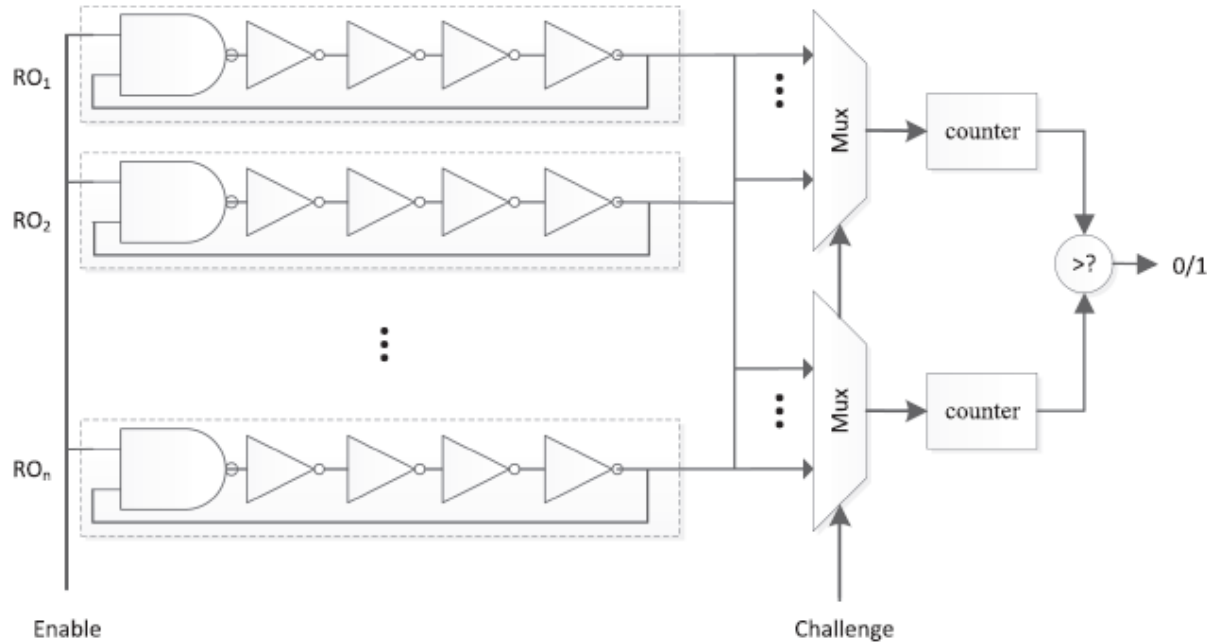
Replay Attacks

- Replaying the previous FPGA configurations



- FPGA design logic is secure so long as configuration bits are protected

PUF (Physically Unclonable Function)



- Multiple Ring Oscillators (RO₁, RO₂, ..., RO_n)
- Two multiplexers (MUXes)
- Two counters
- A comparator that outputs 0 or 1
- A challenge that selects which oscillators to compare
- An enable signal that activates the oscillators

If RO_i is faster, Counter1 > Counter2 → output 1

If RO_j is faster, Counter2 > Counter1 → output 0

By applying many (i, j) pairs, the system generates a **response vector** → a unique device fingerprint.

Replay attack

Before deployment:

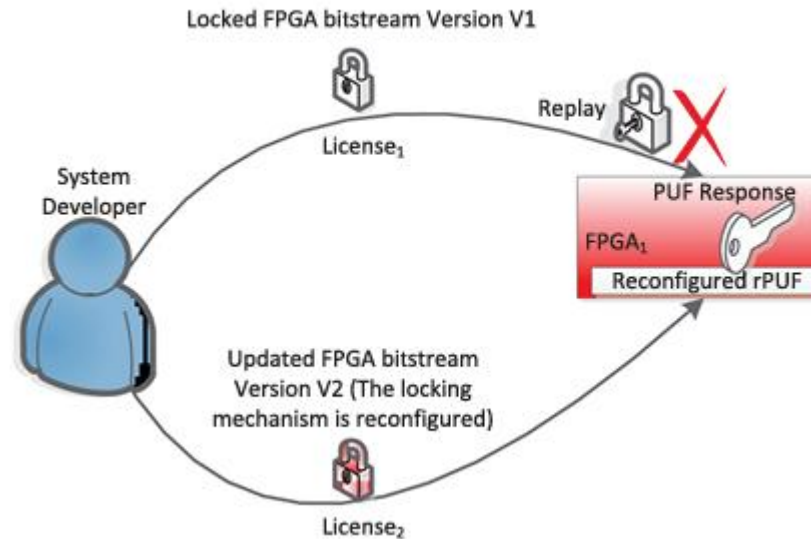
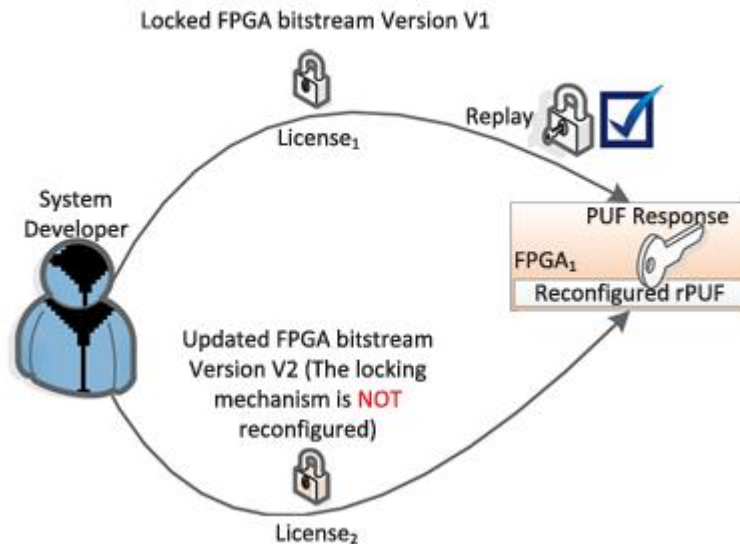
FPGA manufacturer or developer queries the PUF.

PUF gives a **unique response R**.

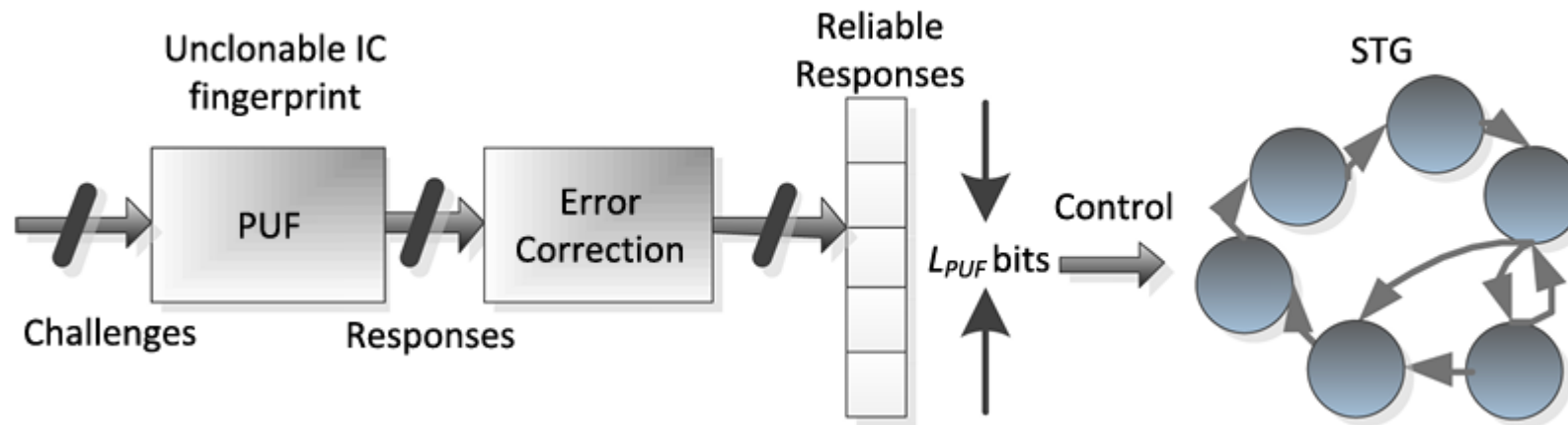
Developer computes:

$\text{License}_1 = f(R)$

Developer embeds **License₁** inside the bitstream V1.

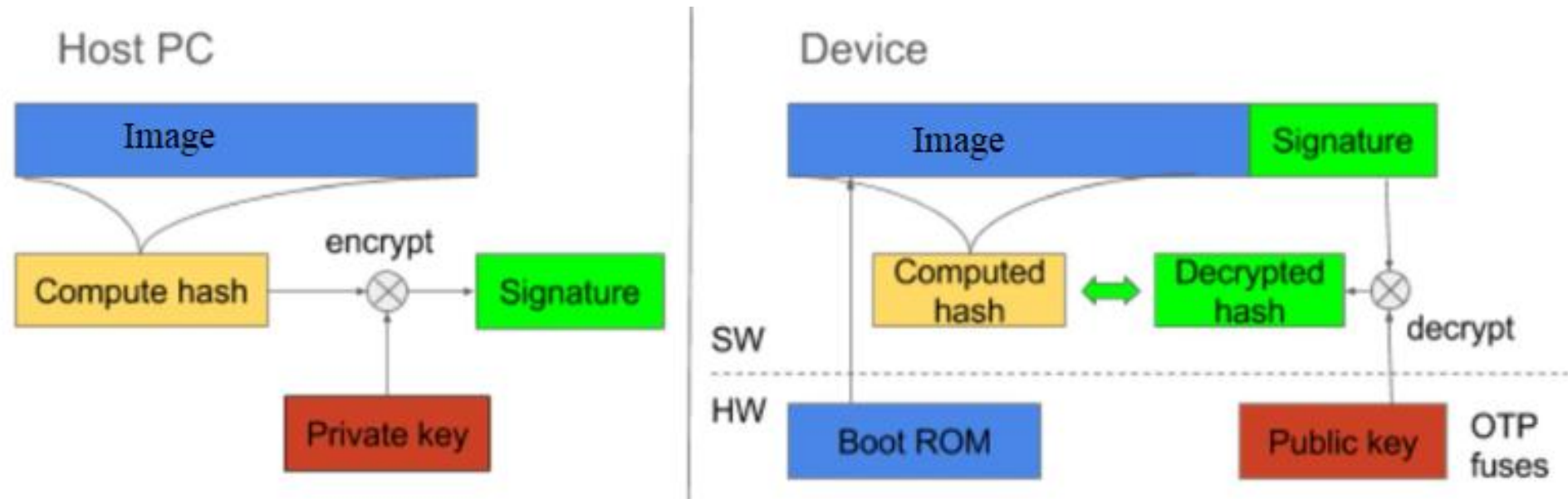


Replay attack



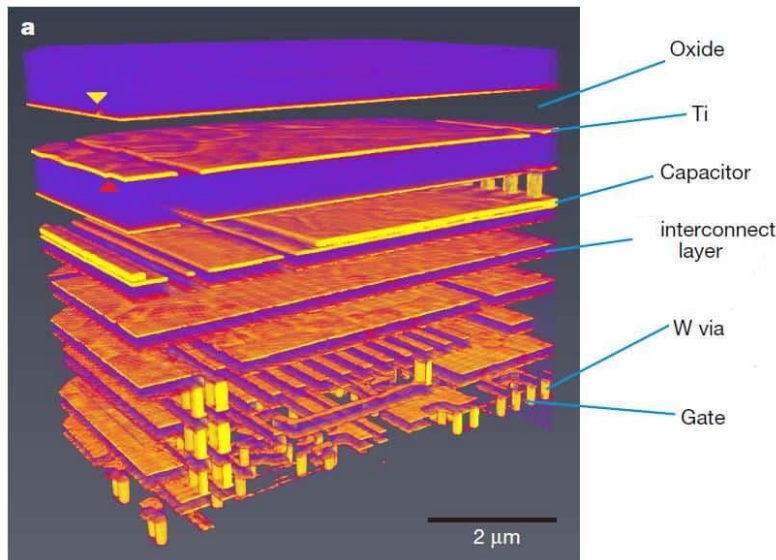
- The license bits flow to the STG (the State Transition Graph, which represents the finite state machine or FSM).
- The transitions (paths and states) within the FSM are specifically controlled by the PUF response.
 - Only with the correct bits will the FSM operate properly.
 - If the response is incorrect or missing, the circuit will not function as intended (“locked”).

Secure boot/ Start



Reverse Engineering attack (ASIC)

- IC reverse engineering mainly includes gate-level netlist reverse engineering and **image processing-based reverse engineering**.
- X-ray tomography is a nondestructive method that can provide layer-by-layer images of chips and is often used for the analysis of internal vias, traces, wire bonding, capacitors, contacts, or resistors.

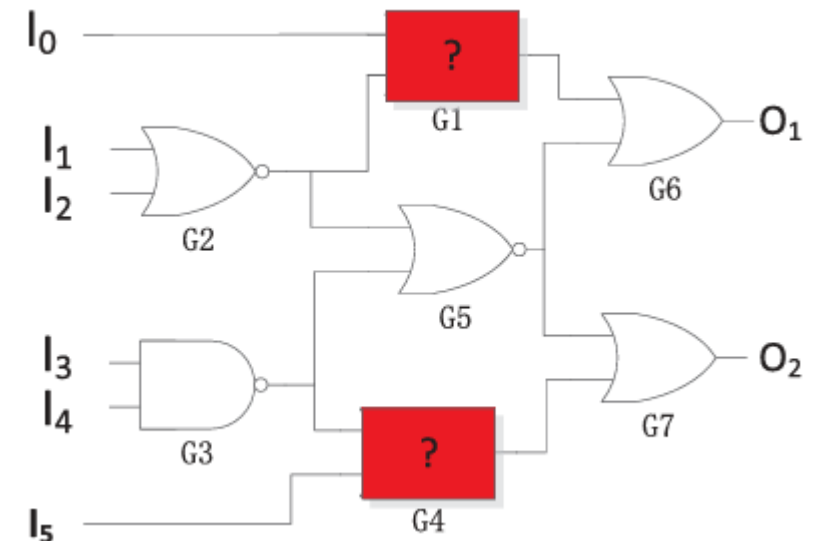


IC camouflage

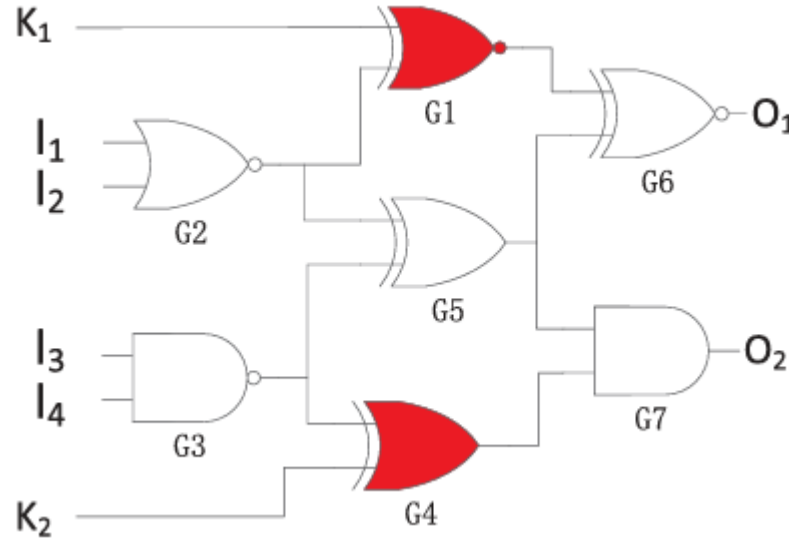
- Camouflaged gates are designed to look identical physically, *even under advanced imaging techniques*. Their logical function (AND, OR, NAND, etc.) is hidden by clever choices of layout, doping, or dummy contacts.

The technology is designed so that imaging cannot distinguish the real contacts from dummies

Only electrical probing (cutting open the chip, which is destructive and very challenging for advanced processes) could potentially distinguish their function.



Logic obfuscation



- Red gates (G_1 & G_4) take inputs called K_1 and K_2 (the *secret keys*) along with regular signals.
- If wrong keys are input, the logic will NOT function correctly. It may be completely scrambled or act unpredictably.

Physical Tampering

- Many secure FPGAs (e.g., Microchip/Microsemi, Xilinx Zynq UltraScale+ MPSoC) include **tamper-detect input pins** that can be wired to external sensors
- Light sensors to detect opening of the casing
- Micro-switches on enclosure doors
- Pressure or vibration sensors for intrusion
- In case of a tamper event, critical data is e.g. cleared and the system is shut down. Zeroization (Key and Configuration Erasure)
 - Include JTAG disable as well.